Your Security Co.

Web Application Penetration Test Report

Example Corp

Project ID: PT-2026-001
Report Date: _____

Executive Summary

This report documents 3 finding(s) identified during the assessment. Each finding is rated by severity and CVSS, with a proof of concept and remediation guidance. Findings are ordered most-severe first.

Scope

- app.example.com — Primary web application (HTTPS / tcp 443)

Findings by Severity

Severity	Count
High	2
Low	1

Detailed Findings

1. Business-Logic Race Condition in Fund Transfer (TOCTOU)

Severity	CVSS v3.1
High	8.2

Description

The transfer endpoint validates the requested amount against the account balance and then debits the account as two separate, non-atomic steps. Concurrent requests all read the same starting balance, all pass the check, and all debit.

A low-privileged user can therefore move more funds than they hold, driving the source account to a negative balance.

Proof of Concept

```
Fire N identical transfers simultaneously with a thread barrier:
control: 1 x POST /api/transfer {amount: 20000} -> 400 Insufficient funds
race : 20 x POST /api/transfer {amount: 13000} -> 7 x 200 Transfer successful
balance 13,000 -> -78,000
```

Recommendations

- Perform the debit atomically and conditionally: UPDATE accounts SET balance = balance - :amt WHERE id = :id AND balance >= :amt; treat zero rows affected as insufficient funds.
- Or wrap check + debit + credit in a single serializable transaction with a row lock.

2. Stored Cross-Site Scripting in Support Messages

Severity	CVSS v3.1
High	8.1

Description

User-supplied message content is stored without sanitization and rendered as raw HTML, so a stored payload executes in a support agent's authenticated session when they open the ticket.

Proof of Concept

```
POST /api/messages {"message":"<img src=x onerror=alert(document.domain)>"} -> stored verbatim
Agent opens the ticket -> payload executes in their session
```

Recommendations

- Render user content as text, not HTML; if rich HTML is required, sanitize on output with an allowlist (e.g. DOMPurify).
- Deploy a Content-Security-Policy (default-src 'self'; no unsafe-inline) as defense-in-depth.

3. Missing HTTP Security Headers

Severity	CVSS v3.1
Low	3.1

Description

Standard security response headers (HSTS, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy) are absent, weakening defense-in-depth and amplifying the impact of client-side injection.

Proof of Concept

```
Response headers on / and /api/* omit: Strict-Transport-Security, Content-Security-Policy,
X-Frame-Options, X-Content-Type-Options, Referrer-Policy.
```

Recommendations

- Add CSP, HSTS (max-age >= 31536000; includeSubDomains), X-Frame-Options: DENY, and X-Content-Type-Options: nosniff (e.g. via helmet).